

Types of Cyber Attacks

Detailed defensive and educational guide for the CyberRAG knowledge base

1. What is a Cyber Attack?

A cyber attack is an intentional attempt to compromise the confidentiality, integrity, or availability of a computer system, network, application, account, device, or information. Common objectives include unauthorized access, data theft, fraud, disruption, surveillance, sabotage, or extortion.

2. Attack, Threat, and Vulnerability

A threat is a potential cause of harm. A vulnerability is a weakness. An attack is an attempt to compromise a target or take advantage of a weakness. An exploit is a technique or mechanism used to take advantage of a vulnerability.

3. Phishing Attacks

Phishing uses deception and impersonation to trick victims into revealing information, opening malicious content, visiting fraudulent websites, or performing unsafe actions. Variants include email phishing, spear phishing, whaling, smishing, vishing, and business email compromise. Defenses include independent verification, careful inspection of links, MFA, email filtering, and reporting suspicious messages.

4. Brute-Force and Password Guessing

These attacks repeatedly attempt credentials until a valid combination is found. Dictionary attacks use likely passwords or words. Defenses include long unique passwords, password managers, MFA, rate limiting, lockout or risk-based controls, and monitoring repeated failures.

5. Password Spraying and Credential Stuffing

Password spraying tests a small number of common passwords against many accounts. Credential stuffing attempts to reuse credentials exposed in other breaches. Defenses include unique passwords, MFA, breached-password protection, rate limiting, and detection of unusual login behavior.

6. DoS and DDoS Attacks

A denial-of-service attack attempts to make a service unavailable by exhausting bandwidth, connections, processing power, memory, or application resources. A distributed denial-of-service attack uses many sources. Defenses include rate limiting, traffic filtering, redundancy, load balancing, content delivery infrastructure, and DDoS mitigation.

7. Man-in-the-Middle Attacks

A man-in-the-middle attack involves unauthorized interception of communication between parties and may allow observation or alteration of data. Defenses include HTTPS and modern TLS, correct certificate validation, secure network practices, and caution on untrusted networks.

8. Spoofing Attacks

Spoofing falsifies an identity, address, sender, or trusted resource. Examples include email, IP, DNS, or network identity spoofing. Defenses include strong authentication, email security controls, secure DNS practices, monitoring, and identity verification.

9. Web Application Attacks

Web applications may be attacked through weaknesses in input handling, authentication, authorization, session management, configuration, or dependencies. Examples include injection, cross-site scripting, broken access control, insecure authentication, and security misconfiguration. Defenses include secure coding, parameterized queries, input validation, output encoding, authorization checks, patching, and testing.

10. SQL Injection

SQL injection can occur when an application handles input unsafely and allows unintended manipulation of database queries. Potential impact includes unauthorized data access or modification. Defenses include parameterized queries, safe database APIs, input validation, least-privileged database accounts, and security testing.

11. Cross-Site Scripting (XSS)

XSS occurs when untrusted content is handled in a way that allows unintended script execution in a user's browser context. Impact may include session compromise or content manipulation. Defenses include context-aware output encoding, secure input handling, content security policies, and secure session practices.

12. Cross-Site Request Forgery (CSRF)

CSRF attempts to cause a user's authenticated browser to send an unwanted request. Defenses include anti-CSRF tokens, appropriate cookie settings, origin validation, and additional confirmation for sensitive actions.

13. Session Hijacking

Session hijacking attempts to take over an authenticated session by obtaining or abusing a valid session identifier or token. Defenses include HTTPS, secure and HttpOnly cookies where applicable, short session lifetimes, token rotation, logout controls, and monitoring unusual session behavior.

14. Malware-Based Attacks

Malware can be used to steal data, disrupt systems, spy on users, encrypt files, or maintain unauthorized access. Common forms include viruses, worms, Trojans, ransomware, spyware, keyloggers, rootkits, bots, and backdoors. Defenses include patching, endpoint protection, least privilege, backups, application control, and monitoring.

15. Ransomware Attacks

Ransomware restricts access to data or systems, often through encryption, and may also involve theft and extortion. Defenses include protected and tested backups, MFA, rapid patching, network segmentation, endpoint monitoring, and a rehearsed incident response plan.

16. Watering Hole Attacks

A watering hole attack targets a website or resource likely to be used by a particular group, attempting to compromise visitors through a trusted or frequently used location. Defenses include browser updates, endpoint protection, network monitoring, and reducing exposure to compromised sites.

17. Drive-by Compromise

A drive-by compromise exposes users to malicious or compromised online content, sometimes without an obvious download. Defenses include updated browsers, reduced unnecessary plug-ins, security controls, and investigation of suspicious redirects.

18. Supply-Chain Attacks

A supply-chain attack compromises a trusted supplier, dependency, service, update mechanism, or distribution path. Defenses include supplier assessment, software inventories, dependency management, integrity verification,

controlled updates, and monitoring.

19. Insider Attacks

An insider attack involves intentional misuse of legitimate access by a trusted person or abuse of a compromised legitimate account. Defenses include least privilege, access reviews, separation of duties, logging, monitoring, and secure offboarding.

20. Advanced Persistent Attacks

These are targeted intrusions where attackers attempt to maintain access for extended periods, emphasizing persistence and stealth. Defenses include centralized logging, endpoint and identity monitoring, segmentation, threat hunting, incident response, and rapid containment.

21. Zero-Day Exploitation

Zero-day exploitation targets a vulnerability before an effective fix is available or broadly deployed. Defenses include defense in depth, behavior-based monitoring, isolation, least privilege, segmentation, reducing unnecessary exposed services, and rapid patching when available.

22. DNS and Network Redirection

These attacks attempt to redirect users or systems to unintended destinations by abusing trust relationships in name resolution or network communication. Defenses include secure DNS practices, strong network controls, monitoring, encryption, and validation of destinations.

23. Replay Attacks

A replay attack attempts to reuse previously captured valid communications or authentication information. Defenses include nonces, timestamps, short-lived tokens, sequence checking, and authenticated protocols designed to resist reuse.

24. Privilege Escalation

Privilege escalation occurs when limited access is used to obtain greater permissions. Defenses include least privilege, patching, secure configuration, access reviews, hardening, and monitoring unusual privilege changes.

25. Lateral Movement

After initial access, an attacker may move between systems or accounts to reach more valuable assets. Defenses include segmentation, identity controls, privileged access management, credential protection, and monitoring.

26. Data Exfiltration

Data exfiltration is the unauthorized transfer of information to an external location. Targets can include credentials, customer information, intellectual property, source code, and confidential documents. Defenses include access control, monitoring, encryption, data classification, and investigation of unusual outbound activity.

27. Cloud Account and API Attacks

Cloud environments can be targeted through exposed credentials, excessive permissions, insecure APIs, misconfigured storage, and compromised accounts. Defenses include MFA, least-privilege IAM, secrets management, secure API authentication, configuration reviews, logging, and monitoring.

28. IoT and Embedded Device Attacks

Connected devices may be attacked through default credentials, outdated firmware, exposed services, insecure configuration, or weak authentication. Defenses include changing defaults, firmware updates, disabling unnecessary services, segmentation, and monitoring.

29. Mobile Attacks

Mobile attacks can involve malicious apps, fake apps, spyware, SMS phishing, unsafe permissions, insecure networks, or outdated software. Defenses include trusted app sources, permission review, updates, device encryption, screen locks, and account protection.

30. Physical and USB-Based Attacks

Physical attacks can involve stolen devices, unauthorized equipment access, tampering, or untrusted removable media. Defenses include physical access controls, device encryption, secure storage, asset management, removable-media controls, and secure disposal.

31. Common Attack Lifecycle

Many attacks can involve target selection, initial access, execution, persistence, privilege escalation, discovery, lateral movement, collection, impact, or data exfiltration. Not every attack follows every stage, and the sequence varies.

32. Common Warning Signs

Possible indicators include repeated failed logins, unusual login locations, unexpected administrator accounts, suspicious processes, abnormal network traffic, unauthorized configuration changes, unusual outbound data transfers, unexpected file encryption, suspicious email activity, or alerts from security tools.

33. General Defense Strategy

Maintain updated systems, strong unique credentials and MFA, least privilege, secure configurations, network segmentation, protected tested backups, security monitoring, phishing awareness, vulnerability remediation, and practiced incident response and recovery procedures.

34. Summary

Cyber attacks can target people, applications, networks, devices, identities, cloud services, and physical assets. Effective cybersecurity requires layered preventive, detective, response, and recovery controls.

CyberRAG Knowledge Base Note: Each attack type is separated into a focused section to improve retrieval for questions such as “What is session hijacking?”, “What is credential stuffing?”, or “How do supply-chain attacks work?”